

MODULE 20 · DOMAIN 2 - DESIGN FOR NEW SOLUTIONS

Security Controls for New Solutions

Encryption is easy. Deciding who may decrypt is the architecture.

DOMAIN 2 of 4 EXAM WEIGHT 29% MODULE 20 of 44

Turning encryption on is a checkbox. **The key policy is the architecture.**

Three kinds of KMS key

- ◆ **AWS owned** keys are shared across customers, invisible to you, and free. The default where you configure nothing.
- ◆ **AWS managed** keys appear in your account with an aws slash prefix. You can see their use in CloudTrail and cannot edit their policy.
- ◆ **Customer managed** keys are yours: your key policy, your rotation setting, your grants. Charged monthly plus per request.
- ◆ Cross-account sharing, custom rotation and audit control all require a **customer managed** key.

ON THE EXAM

Any requirement to control, share or audit the key itself forces a customer managed key. That is the usual signal.

Key policy, IAM, and grants

- ◆ **The key policy is the root of authority.** If it does not delegate to IAM, no IAM policy in that account can grant access.
- ◆ The default key policy contains a statement enabling IAM. Remove it and only the key policy grants anything.
- ◆ **Grants** give temporary, narrow permissions, often created by AWS services on your behalf. They can be retired.
- ◆ Cross-account use needs the **key policy** to allow the other account, **and** IAM in that account to allow the caller.

ON THE EXAM

An administrator who cannot decrypt is nearly always a key policy that never delegated to IAM. Module two's chain, with an extra door.

Envelope encryption and multi-Region keys

- ◆ **Envelope encryption:** KMS encrypts a data key, the data key encrypts your data. KMS never sees the data.
- ◆ This is why a 5 GB object works. Only the small data key travels to KMS, not the payload.
- ◆ **Multi-Region keys** share key material across Regions, so ciphertext encrypted in one decrypts in another.
- ◆ Each replica needs **its own key policy**, and is charged separately in its Region. They are not one key.

ON THE EXAM

Ordinary KMS keys are Region-bound. Copying an encrypted snapshot cross-Region re-encrypts it with a key in the destination.

Rotation, and what changed

- ◆ **Automatic rotation is now configurable from 90 to 2,560 days.** It was a fixed 365 days before 2024.
- ◆ **On-demand rotation** exists, with a lifetime limit of ten per key.
- ◆ Rotation changes the key material, not the key ID. Old material is kept so existing ciphertext still decrypts.
- ◆ **Not supported** for asymmetric keys, HMAC keys, or keys in a CloudHSM custom key store.

ON THE EXAM

AWS managed keys rotate annually and you cannot change that. A specific rotation interval requires a customer managed key.

Secrets Manager or Parameter Store?

SECRETS MANAGER

Built for secrets that rotate

- Built-in rotation with Lambda
- Native RDS and Redshift integration
- Cross-Region replication of secrets
- Charged per secret per month

PARAMETER STORE

Configuration, and cheap secrets

- Standard tier is free
- SecureString encrypts with KMS
- No built-in rotation
- Advanced tier for larger values

THE TIEBREAKER

Automatic rotation is the separator. Without that requirement, Parameter Store SecureString does the job for nothing.

Certificates and hardware

- ◆ **ACM public certificates are free** and renew automatically, and can only be attached to AWS services such as ALB, CloudFront and API Gateway.
- ◆ **ACM cannot export a public certificate.** For a certificate on an EC2 instance you need Private CA or a third party.
- ◆ **AWS Private CA** issues internal certificates, at a monthly cost per CA plus per certificate.
- ◆ **CloudHSM** is single-tenant, FIPS 140-3 Level 3 hardware where you control the key material and AWS cannot see it.

ON THE EXAM

CloudHSM appears when a regulator demands sole control of key material, or a specific FIPS level KMS does not meet.

Shield Standard or Shield Advanced?

SHIELD STANDARD

On already, and free

- Automatic for every AWS customer
- Layer 3 and 4 volumetric attacks
- No console, no configuration
- Handles the large majority of attacks

SHIELD ADVANCED

\$3,000 a month, per organisation

- DDoS Response Team, 24/7
- Cost protection for attack-driven scaling
- Standard WAF fees included
- Layer 7 protections and visibility

THE TIEBREAKER

Shield Advanced is one \$3,000 charge for the whole organisation, and it absorbs standard WAF costs on protected resources.

AWS WAF

- ◆ **Managed rule groups** cover the OWASP top ten, known bad inputs and IP reputation, maintained by AWS.
- ◆ **Rate-based rules** block a source exceeding a request threshold. The usual answer for brute force and scraping.
- ◆ **Bot Control** and **Account Takeover Prevention** are paid additions, and are **not** covered by Shield Advanced.
- ◆ Attaches to CloudFront, ALB, API Gateway, AppSync and Cognito. **Not** to a Network Load Balancer.

ON THE EXAM

Use scope-down statements so expensive rule groups only inspect the pages that need them, such as login and checkout.

Reading the scenario

THE SCENARIO SAYS

An admin with full IAM cannot decrypt

Encrypted snapshots usable in another Region

Database credentials must rotate automatically

Config values, cost matters, no rotation needed

Sole control of key material, FIPS 140-3 Level 3

Bill spiked during a DDoS attack

IT IS POINTING AT

The key policy never delegated to IAM

A multi-Region KMS key

Secrets Manager

Parameter Store SecureString

AWS CloudHSM

Shield Advanced cost protection

ON THE EXAM

Ask where the key lives and who the policy names. Most KMS questions are answered by those two facts alone.

A new engineer with the AdministratorAccess policy cannot read objects from an encrypted S3 bucket, receiving an access denied error on kms:Decrypt. Other engineers can. The bucket policy grants the whole account, and the engineer's IAM permissions are unrestricted.

The key is a customer managed key created two years ago by a security engineer who has since left.

What is the MOST likely cause?

- ☐ A The key policy does not include the statement that delegates access control to IAM
- ☐ B The engineer's IAM policy needs an explicit allow for kms:Decrypt
- ☐ C The key has been scheduled for deletion
- ☐ D The key needs rotating; the old material has expired

◆ PAUSE AND DECIDE

What is the MOST likely cause?

- A

 Key policy does not delegate to IAM
Without that statement, only principals the key policy names can use the key. The other engineers are named; the new one is not.
- B

 Add kms:Decrypt to IAM
AdministratorAccess already allows every KMS action. If IAM had any say, this would already work.
- C

 Scheduled for deletion
A key pending deletion is unusable by everyone. Other engineers can decrypt, so the key is healthy.
- D

 Old material expired
KMS retains old key material indefinitely so existing ciphertext still decrypts. Material does not expire.

THE SIGNAL

Some principals work and others do not, with identical IAM. That points at a policy naming principals individually.

A company encrypts EBS snapshots with a customer managed key in eu-west-1 and copies them to eu-central-1 for disaster recovery. During a DR drill, the copied snapshots could not be used to launch instances.

The team wants encrypted snapshots that are directly usable in either Region.

What should the solutions architect recommend?

- ☐ A Use a multi-Region KMS key, replicated to eu-central-1
- ☐ B Share the eu-west-1 key with eu-central-1 through its key policy
- ☐ C Disable encryption on the snapshots before copying them
- ☐ D Enable automatic key rotation on the existing key

◆ PAUSE AND DECIDE

What should the solutions architect recommend?

- A** Multi-Region key
Replicas share key material, so ciphertext encrypted in one Region decrypts in another with no re-encryption step.
- B** Share the key by policy
A key policy grants access to principals, not to Regions. An ordinary KMS key cannot be used outside its own Region at all.
- C** Disable encryption
Solves a key problem by removing the protection. Unencrypted DR copies of production data are rarely acceptable.
- D** Enable rotation
Changes key material on a schedule. It has no bearing on which Region a key can be used in.

THE SIGNAL

KMS keys are Region-bound. That single fact is what makes cross-Region DR of encrypted data a design decision.

An audit requires that database credentials for 40 RDS instances change every 30 days with no human involvement, and that the change is applied to both the database and the applications reading it.

The team currently stores credentials in Parameter Store SecureString parameters and changes them by hand each quarter.

What should the solutions architect recommend?

- ☐ A Keep Parameter Store and write a Lambda function on a 30-day schedule
- ☐ B Move the credentials to Secrets Manager and enable managed rotation for RDS
- ☐ C Use Parameter Store Advanced tier, which adds rotation
- ☐ D Store the credentials in a KMS-encrypted S3 object and rotate that

◆ PAUSE AND DECIDE

What should the solutions architect recommend?

A Custom Lambda rotation

Rebuilds Secrets Manager's rotation, including changing the password in RDS without breaking live connections. It is harder than it looks.

C Parameter Store Advanced

Advanced tier adds larger values, more parameters and policies. It does not add credential rotation.

B Secrets Manager managed rotation

Rotation is built in, and the RDS integration changes the password in the database and the secret together.

D Encrypted S3 object

Turns a solved problem into a bespoke one, with no rotation, no versioning semantics for secrets, and no database integration.

THE SIGNAL

Automatic rotation is the one thing Parameter Store does not do. That requirement alone decides between the two services.

A regulated payments provider must generate and store the private keys used to sign transactions. The regulator requires that no third party, including the cloud provider, can access the key material, and mandates FIPS 140-3 Level 3 validated hardware.

The team currently uses a KMS customer managed key.

What should the solutions architect recommend?

- ☐ A Keep the KMS customer managed key and enable automatic rotation
- ☐ B AWS CloudHSM, with the application using the HSM directly
- ☐ C A KMS key with imported key material
- ☐ D Store the private keys in Secrets Manager

◆ PAUSE AND DECIDE

What should the solutions architect recommend?

- A

 KMS with rotation
KMS is multi-tenant and AWS operates it. Rotation is irrelevant to a requirement about who can reach the key material.
- B

 CloudHSM
Single-tenant, FIPS 140-3 Level 3 hardware where you hold the credentials and AWS has no access to the key material.
- C

 Imported key material
The closest miss. You generate the material, and it still lives in and is operated by AWS KMS afterwards.
- D

 Secrets Manager
A secret store, not a cryptographic module. It performs no signing and meets no FIPS hardware requirement.

THE SIGNAL

Two requirements: no provider access, and a specific FIPS level. Only CloudHSM satisfies both, which is why it exists.

A retailer's login page is being attacked by credential stuffing from thousands of rotating IP addresses. Each individual address sends only a few requests per minute, so rate-based rules have not helped. Legitimate customers must not be blocked.

The site already uses CloudFront with AWS WAF and managed rule groups.

What should the solutions architect recommend?

- A Lower the rate-based rule threshold until the attack stops
- B Add WAF Account Takeover Prevention, scoped down to the login endpoint
- C Subscribe to Shield Advanced, which covers this automatically
- D Block the attacking countries with a geo-match rule

◆ PAUSE AND DECIDE

What should the solutions architect recommend?

- A

 Lower the rate threshold
Each address is already below any sane threshold. Lowering it far enough to catch them starts blocking real customers.
- B

 Account Takeover Prevention, scoped down
Built for credential stuffing, inspecting login attempts rather than counting requests. Scoping it down keeps the cost to the login path.
- C

 Shield Advanced
Focused on DDoS, and Account Takeover Prevention is explicitly not covered by the subscription. It would not solve this.
- D

 Geo-blocking
Blunt and unreliable. Attackers move proxies, and legitimate customers travel.

THE SIGNAL

Rate-based rules count requests per source. An attack spread across thousands of sources is invisible to them by design.

During a sustained DDoS attack last quarter, a media company's Auto Scaling groups and CloudFront usage scaled up sharply and the monthly bill rose by \$180,000. The security team also spent eleven hours on the phone without expert assistance.

The company runs 30 accounts under one organisation.

What should the solutions architect recommend?

- A Shield Advanced, for cost protection and DDoS Response Team access
- B Set AWS Budgets alerts so finance is warned during the next attack
- C Lower the Auto Scaling maximum capacity so costs cannot spike
- D Rely on Shield Standard, which already mitigates volumetric attacks

◆ PAUSE AND DECIDE

What should the solutions architect recommend?

- A** Shield Advanced
Cost protection credits attack-driven scaling charges, and the response team addresses the eleven hours. \$3,000/month is charged once for the whole organisation.
- B** Budgets alerts
Tells finance the bill is rising during an attack they already know about. It prevents no charge and mitigates nothing.
- C** Cap Auto Scaling
Converts a cost problem into an outage. The attack now succeeds in taking the site down, cheaply.
- D** Shield Standard only
Already in place, and it is what the company had during the attack described. Nothing would change.

THE SIGNAL

Two symptoms, one service. Cost protection and the response team are both Shield Advanced features and nothing else's.

What to carry out of this module

- ◆ **The key policy is the root of authority.** Without a delegation statement, no IAM policy in the account grants KMS access.
- ◆ **KMS keys are Region-bound.** Cross-Region use of ciphertext needs a multi-Region key.
- ◆ **Rotation is the Secrets Manager separator.** Without it, Parameter Store SecureString is free and sufficient.
- ◆ **Shield Advanced is \$3,000 per organisation,** buying cost protection and the response team. Bot Control is extra.

ON THE EXAM

CloudHSM answers only two requirements: sole control of key material, and a FIPS level KMS does not meet. Otherwise it is over-engineering.